

COMSATS University Islamabad
Wah Campus

Department of Computer Science
Bachelor of Science in Software Engineering

SEMESTER PROJECT PROPOSAL
Information Security

Hit & Check

A Cybersecurity Awareness & PIN Strength Simulation Platform

Submitted By

Muhammad Akif Naveed | CIIT/FA24-BSE-129/WAH
Hamza Ali | CIIT/FA24-BSE-124/WAH
Arsalan Shafique | CIIT/FA24-BSE-119/WAH

Academic Year: 2024–2025
Semester: FA-2024

1. Project Overview

Project Title:

Hit & Check — A Cybersecurity Awareness & PIN Strength Simulation Platform

Course:

Information Security

Project Summary:

Hit & Check is a Python Streamlit-based cybersecurity awareness application designed to educate users about the critical weakness of 4-digit numeric PINs against brute-force and dictionary attacks. The application accepts a user-provided demo PIN, applies an educational encryption transformation, then simulates an attacker systematically trying all 10,000 possible 4-digit combinations. It records attack metrics, generates visual analytics, and leverages the Groq AI API to produce a detailed, human-readable security report.

The project targets students, professionals, and general users who wish to understand why short numeric PINs provide inadequate security. It serves as a safe, legal, and ethical cybersecurity education tool — not a malicious application.

Ethical & Safety Commitment:

Hit & Check operates strictly within ethical boundaries. It performs simulations only on user-provided demo PINs within the application environment. No real banking credentials are processed, stored, or transmitted. All attack simulations are contained within the app interface. The application includes a Safe Awareness Demo that simulates the appearance of a cyberattack in a clearly labelled, controlled, stoppable in-app environment — no actual system modifications, no persistent processes, no harmful payloads.

2. Project Team

Student Name	Registration No.	Role
Akif Naveed Malik	CIIT/FA24-BSE-129/WAH	AI & Lead Developer, cloud deployment, system architecture, email automation
Hamza Ali	CIIT/FA24-BSE-124/WAH	Backend & Json, Unit testing, Database design and implementtion
Arsalan	CIIT/FA24-BSE-119/WAH	UI & UX Design. Slides, awareness demo, documentation

3. Objectives

This project aims to achieve the following educational and technical objectives:

- Demonstrate the vulnerability of 4-digit numeric PINs through live simulation.
- Implement and explain educational encryption transformations (Caesar Shift, Substitution Cipher, SHA-256 Reduced Hash).
- Simulate brute-force and dictionary-based attacks within the application.
- Quantify attack risk using a scoring engine that calculates strength score and hack probability.
- Integrate the Groq AI API to generate detailed, plain-language security reports.
- Provide an interactive chatbot to answer user questions about cybersecurity best practices.
- Deliver automated email reports containing analysis results and recommendations.
- Include an in-app Safe Awareness Demo to illustrate social engineering and scareware techniques in an educational context.
- Deploy the fully functional application on Streamlit Community Cloud.

4. Proposed Features

4.1 User Input & Validation

- User name and optional email address
- Demo 4-digit numeric PIN entry
- Encryption method selection (dropdown)
- Attack type selection: Brute Force, Dictionary Attack, or Combined
- PIN validation: exactly 4 numeric digits; warning against entering real banking PINs

4.2 Encryption / Educational Transformation Algorithms

Three educational transformations will be offered. These are clearly labelled as simulation tools, not banking-grade encryption:

- Caesar Digit Shift — each digit shifted by $+3 \bmod 10$ (e.g., 1234 becomes 4567)
- Digit Substitution Cipher — fixed mapping table (e.g., $0 \rightarrow 7$, $1 \rightarrow 3$, $2 \rightarrow 9$, ...)
- SHA-256 Reduced Demo Hash — full SHA-256 hash reduced to 4 numeric digits via modular arithmetic for simulation purposes

4.3 Attack Simulation Engine

- Brute Force Attack: iterates all combinations 0000–9999, compares transformed candidate against transformed PIN, records attempts and timing
- Dictionary Attack: prioritises a list of 10+ common weak PINs (0000, 1111, 1234, 7777, etc.) before falling back to full brute force
- Combined Attack: dictionary phase followed immediately by full brute force sweep
- All simulations record: cracked PIN, encrypted form, total attempts, attack duration, estimated real-world crack time

4.4 Scoring & Risk Metrics

- Strength Score (0–100)
- Hack Probability (0–100%)
- Risk Level classification: Low / Medium / High / Critical
- Crack position percentile (how early in the search space the PIN was found)
- Estimated crack time under realistic attack speeds

4.5 Dashboard & Visualisations

- Overview panel: name, algorithm, encrypted PIN, attack type, attempts, risk level
- Metric cards: Attempts to Crack, Total PIN Space, Strength Score, Hack Probability, Crack Time
- Bar chart: attack attempts vs. total combination space
- Line chart: brute-force progress over iterations
- Pie chart: cracked position percentage vs. remaining search space
- Gauge-style score visualisation

4.6 AI-Powered Report (Groq Integration)

- Structured JSON payload sent to Groq API
- Returns: summary, strength score, risk level, findings list, recommendations, attack explanation, educational note
- Displayed in a dedicated Report section of the dashboard
- Real PIN is never included in any prompt or API call

4.7 Security Awareness Chatbot

- Powered by Groq API
- Answers user questions: "Why is my PIN weak?", "What is brute force?", "How do I avoid phishing?", etc.
- Passes limited, sanitised context; never requests or stores sensitive data
- Constrained to security awareness topics only

4.8 Email Report Delivery

- "Get Report on Email" button on the dashboard
- Sends: user name, strength score, risk level, key findings, recommendations
- Delivered via SMTP (Gmail App Password) or SendGrid/Brevo free tier
- No executable attachments, no malware, no hidden payloads
- Streamlit secrets used for credential management on Streamlit Cloud

4.9 Safe Awareness Demo

- "Run Safe Attack Awareness Demo" button inside the dashboard
- Displays simulated scareware-style warnings in-app with clear educational labels
- Examples: "This is how urgency-based phishing works", "Never download attachments from unknown senders"
- Visible "Stop Demo" button; no files are modified; no persistent processes; completely safe and reversible

5. Technology Stack

Category	Technology / Library
Core Framework	Python 3.11+, Streamlit
AI / LLM	Groq API (llama-3 / mixtral models)
Data Processing	Pandas, Python hashlib
Visualisation	Plotly (charts & gauges)
Email Delivery	SMTP (Gmail App Password) or SendGrid / Brevo free tier
Environment Mgmt	python-dotenv (local), Streamlit Secrets (cloud)
Testing	pytest
Deployment	Streamlit Community Cloud + GitHub
Version Control	Git / GitHub

6. JSON API Contracts

6.1 PIN Analysis Request — Sent to Groq

Field	Type	Description
app_name	string	Application identifier: "Hit & Check"
analysis_type	string	Always "pin_strength_report"
user.name	string	User's display name
user.email	string	Optional — for report delivery only
pin_data.pin_length	integer	Always 4 for this application
pin_data.character_set	string	Always "numeric_only"
pin_data.encrypted_pin	string	Transformed PIN (never the real PIN)
pin_data.encryption_method	string	Selected transformation algorithm
pin_data.real_pin_included	boolean	Always false — real PIN never sent
attack_result.attack_type	string	brute_force dictionary combined
attack_result.total_possible_combinations	integer	Always 10000
attack_result.attempts_to_crack	integer	Iteration count at match

attack_result.crack_position_percentage	float	Percentage of space searched
attack_result.estimated_crack_time_seconds	float	Simulated crack duration
risk_metrics.strength_score_out_of_100	integer	Calculated strength score
risk_metrics.hack_probability_out_of_100	integer	Calculated hack probability
risk_metrics.risk_level	string	Low Medium High Critical
instructions.tone	string	"clear, educational, non-technical where possible"
instructions.include_recommendations	boolean	Always true
instructions.do_not_reveal_real_pin	boolean	Always true

6.2 Groq PIN Report Response

Field	Type	Description
summary	string	Plain-language overview of the PIN's weakness
strength_score	integer	0–100 score confirming AI assessment
risk_level	string	Low Medium High Critical
hack_probability	integer	0–100 percentage
attack_explanation	string	Why this attack type is effective
estimated_crack_time	string	Human-readable crack time estimate
key_findings	array<string>	List of specific weaknesses identified
recommendations	array<string>	Actionable improvement suggestions
educational_note	string	Disclaimer reinforcing demo-only use

6.3 Security Chatbot Request

Field	Type	Description
app_name	string	"Hit & Check"
chat_type	string	"security_awareness_assistant"
user_question	string	User's natural language question
context.pin_length	integer	4
context.attack_type	string	Attack type used in current session
context.attempts_to_crack	integer	From current session result
context.risk_level	string	From current session result
rules.do_not_request_real_passwords	boolean	Always true
rules.answer_for_education_only	boolean	Always true

7. Repository & Folder Structure

Repository Name: hit-and-check

Platform: GitHub + Streamlit Community Cloud

Short Description: A Streamlit-based cybersecurity awareness app that demonstrates how 4-digit numeric PINs can be cracked using brute-force and dictionary attacks, with AI-generated security reports powered by Groq.

File / Directory	Purpose
app.py	Main Streamlit application entry point
requirements.txt	Python dependency list for deployment
README.md	Project documentation and setup guide
.gitignore	Excludes secrets, .env, __pycache__, etc.
sample.env	Example environment variable template
.streamlit/config.toml	Streamlit theme and server config
src/__init__.py	Package initialisation
src/config.py	Centralised configuration constants
src/validators.py	PIN format and input validation logic
src/encryption.py	Caesar Shift, Substitution, SHA-256 Reduced
src/attacks.py	Brute-force and dictionary attack engines
src/scoring.py	Strength score and hack probability calculator
src/groq_client.py	Groq API integration and JSON parsing
src/email_service.py	Email report composition and delivery
src/report_builder.py	JSON contract builder for AI requests
src/awareness_demo.py	Safe in-app scareware simulation logic
data/common_pins.json	Top 50+ common/weak 4-digit PINs list
prompts/pin_report_prompt.txt	System prompt for Groq report generation
prompts/chatbot_prompt.txt	System prompt for security chatbot
assets/logo.png	Application logo
tests/test_encryption.py	Unit tests for encryption transformations
tests/test_attacks.py	Unit tests for attack simulation accuracy
tests/test_scoring.py	Unit tests for scoring engine

8. Development Plan

Phase	Name	Deliverables
Phase 1	Foundation	Repo setup, Streamlit UI, PIN validation, encryption methods, brute-force & dictionary simulation
Phase 2	Analysis & Dashboard	Scoring engine, hack probability, crack time estimation, charts, JSON report generation
Phase 3	Groq AI Integration	Groq client, structured PIN strength report prompt, JSON output parsing, AI report display
Phase 4	Chatbot	Security awareness chatbot with limited context, prevents sensitive data handling
Phase 5	Email Report	SMTP/SendGrid integration, HTML email template, Streamlit secrets support
Phase 6	Safe Awareness Demo	In-app simulated attack demo button, educational warnings, visible stop controls
Phase 7	Testing & Deployment	Unit tests, JSON contract tests, Streamlit Cloud deployment, README finalization

9. Safety, Ethics & Scope Boundaries

The following boundaries define what Hit & Check will and will not do:

In Scope (Permitted)	Out of Scope (Strictly Prohibited)
✓ Brute-force simulation on user-provided demo PINs	X Email-triggered virus or executable behaviour
✓ Educational password strength analysis	X Hidden payloads or code that auto-executes
✓ Safe in-app awareness demo with stop controls	X Persistence, evasion, or forced system popups
✓ Automated email of analysis report (text only)	X Code designed to annoy, harm, or damage
✓ Groq AI-powered security recommendations	X Storage or transmission of real banking credentials
✓ Downloadable PDF/text report	X Attack simulations outside the application boundary

10. Expected Outcomes

- A fully deployed, publicly accessible Streamlit web application.
- A functional brute-force and dictionary attack simulator with real-time metrics.
- AI-generated PIN strength reports using the Groq API with structured JSON contracts.
- An interactive chatbot for security awareness Q&A.
- An automated email reporting system.
- A safe, stoppable in-app scareware awareness simulation.
- A clean, well-documented GitHub repository with unit tests and a comprehensive README.
- Demonstrated practical understanding of attack vectors, cryptographic concepts, and secure application design.

11. Future Enhancements

- Extend support to 6-digit and alphanumeric password simulation.
- Add multi-factor authentication (MFA) awareness module.
- Integrate real-time Have I Been Pwned API for leaked PIN checking.
- Support additional AI providers (OpenAI, Mistral) via a provider abstraction layer.
- Add multilingual support (Urdu, Arabic) for wider audience reach.
- Build a teacher/instructor mode for classroom demonstrations.

Declaration

We hereby declare that this project proposal is our own original work, prepared for the Information Security course at COMSATS University Islamabad, Wah Campus. The application described is intended solely for educational and awareness purposes. We commit to adhering to all ethical guidelines, university policies, and legal boundaries throughout the development and deployment of this project.

Muhammad Akif Naveed FA24-BSE-129	Hamza Ali FA24-BSE-124	Arsalan Shafique FA24-BSE-119